ESPECIFICACIÓN DE ARQUITECTURA DE SOFTWARE

Manual de Arquitectura Técnica

Diseño estructural del sistema, modelo C4, desacoplamiento a Firestore aegis-ai-db, orquestación con Gemini 2.0 y modelo de amenazas STRIDE.

React 19 + Node.js Express | Firestore aegis-ai-db | Google GenAI SDK (@google/genai) | GCP Live Telemetry APIs | Modelo STRIDE

Identificador Documental:	DOC-AEGIS-ARCH-2026-V2
Público Objetivo:	Arquitectos de Soluciones Cloud, Ingenieros de Software, SREs y CISOs
Autor / Arquitecto Principal:	AegisAI Open Source Community & Core Security Engineering Team
Patrón Arquitectónico:	Single-Page App (SPA) desacoplada con Backend BFF y Streaming SSE
Topología de Datos:	Base de datos dedicada nombrada: `aegis-ai-db` en Firestore
Fecha de Liberación:	24 de Septiembre de 2026
Clasificación:	Open Source / Public Community Release (Apache 2.0)

Índice de Contenido

1. **1. Visión y Principios Arquitectónicos** — Arquitectura cloud-native y principios de diseño seguro.
2. **2. Diagrama de Arquitectura C4 (Nivel 1 y 2)** — Contexto del sistema y contenedores de ejecución.
3. **3. Capa de Frontend (SPA)** — React 19, Vite, división de bundles y listeners en tiempo real.
4. **4. Capa de Backend y Servicios API** — Express, Server-Sent Events (SSE) y extracción de documentos.
5. **5. Topología de Persistencia y Seguridad (aegis-ai-db)** — Desacoplamiento, esquemas e inmutabilidad.
6. **6. Motor de Telemetría y Escáner de Google Cloud** — Protocolo de conexión y APIs de inspección.
7. **7. Motor de Razonamiento Cognitivo (Gemini LLM)** — Orquestación, Structured Outputs y control de esquema.
8. **8. Modelo de Amenazas de la Solución (STRIDE)** — Análisis de riesgos y controles compensatorios.

1. Visión y Principios Arquitectónicos

La arquitectura de **AegisAI** está concebida bajo cinco principios cardinales de ingeniería:

- **Desacoplamiento Estricto de Datos:** La plataforma no comparte tablas ni colecciones con ninguna otra aplicación del proyecto GCP, operando exclusivamente sobre `aegis-ai-db`.
- **Inmutabilidad Registral (Write-Once, Read-Many):** Cumpliendo con el Invariante 4 de OWASP AI-SVS, una auditoría generada no puede ser modificada ni borrada arbitrariamente.
- **Autenticación Zero-Trust:** Validación criptográfica de identidad federada con Google Workspace en cada invocación.
- **Salida Tipada Rigurosa (Schema Enforcement):** Las evaluaciones generadas por Gemini siguen contratos JSON inquebrantables definidos mediante `responseSchema`.
- **Transmisión Asíncrona con Streaming (SSE):** El análisis de grandes arquitecturas se transmite vía Server-Sent Events para evitar timeouts de red.

2. Diagrama de Arquitectura C4 (Nivel 2: Contenedores)



3. Capa de Frontend (SPA)

El cliente web es una aplicación de una sola página compilada con Vite 6:

- **División de Código (Code Splitting):** Cada vista principal (`Dashboard` , `AuditReportView` , `GcpLiveScannerView`) se carga de manera perezosa con `React.lazy()` y `Suspense` , logrando un bundle inicial de tan solo **36 kB**.
- **Sincronización en Tiempo Real:** El hook `onSnapshot` de Firestore mantiene actualizado el Dashboard ante cualquier cambio o nueva auditoría sin necesidad de recargar la página.
- **Visualización de Métricas:** Biblioteca `Recharts` configurada con paletas adaptadas al nuevo sistema de diseño metálico.

4. Capa de Backend y Servicios API

El backend Express expone servicios REST y canales de streaming SSE:

- `POST /api/gcp/audit` : Orquesta el escaneo en vivo de un proyecto GCP y transmite el progreso paso a paso (Etapas 1 a 6) mediante Server-Sent Events.
- `POST /api/evaluate-architecture` : Recibe un manifiesto técnico y ejecuta la evaluación contra OWASP AI-SVS o ISO 42001.

- `POST /api/custom-frameworks/upload`: Extrae texto y metadatos de documentos regulatorios en PDF, DOCX o JSON con `multer` y `pdf-parse`.

5. Topología de Persistencia y Seguridad (aegis-ai-db)

La persistencia reside exclusivamente en la base de datos `aegis-ai-db`:

```
// firestore.rules para la base aegis-ai-db
rules_version = '2';
service cloud.firestore {
  match /databases/aegis-ai-db/documents {
    function isAuthorizedUser() {
      return request.auth != null;
    }

    match /audits/{auditId} {
      allow read, create, update: if isAuthorizedUser();
      allow delete: if false; // Invariante 4: Inmutabilidad
    }

    match /custom_frameworks/{fwId} {
      allow read, write: if isGoogleEmployee();
    }
  }
}
```

6. Motor de Razonamiento Cognitivo (Gemini LLM)

El motor de evaluación utiliza el nuevo SDK oficial `@google/genai`:

- **Garantía de Esquema (Schema Enforcement):** El modelo recibe un esquema tipado estricto (`Type.OBJECT`) para chapters, puntos probados, matriz RACI y plan de remediación. Es matemáticamente imposible que el modelo devuelva texto plano o markdown suelto.
- **Temperatura Cero (Deterministic Invariance):** Configurado con `temperature: 0.0` para asegurar repetibilidad y consistencia en los veredictos de auditoría.

7. Modelo de Amenazas de la Solución (STRIDE)

AMENAZA (STRIDE)	RIESGO POTENCIAL	CONTRAMEDIDA IMPLEMENTADA EN AEGISAI
Spoofing	Suplantación de identidad de un auditor.	Federación estricta con Google Workspace + validación de dominio en rules.
Tampering	Modificación maliciosa de un veredicto de auditoría.	Regla `allow delete: if false` e inmutabilidad en `aegis-ai-db`.
Repudiation	Negación de autoría en hallazgos críticos.	Firma criptográfica, marca de tiempo ISO y correo del líder técnico en cada reporte.
Information disclosure	Fuga de credenciales o de telemetría de GCP.	Procesamiento de credenciales solo en RAM (Zero-Disk) y permisos de solo lectura.

Denial of Service	Agotamiento de cuotas por prompts masivos.	Límite estricto de caracteres (64k) y streaming con keep-alive a 15 segundos.
Elevation of Privilege	Intento de acceso a colecciones no autorizadas.	Aislamiento total de base de datos dedicada (`aegis-ai-db`).